

CSE241 – Security of Information Systems

Spring 2026

Lecture (2)

Information Security Concepts

Dr. Islam Moursy

Objectives

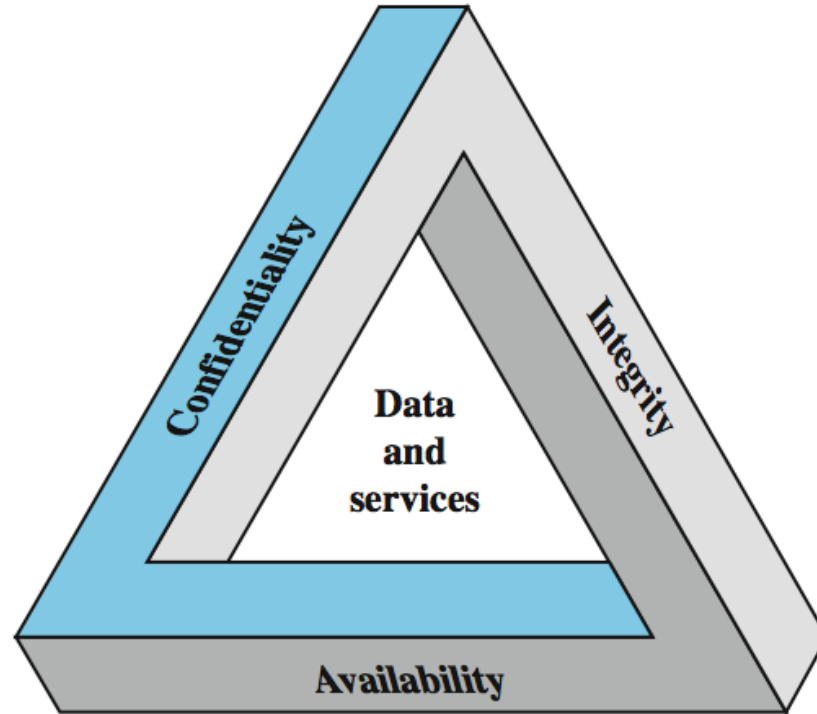
- Describe the key security requirements.
- Define a model for information security
- Discuss the types of security threats and attacks that must be dealt with and give examples of those threats and attacks.
- Explain the fundamental security design principles.
- Discuss the use of attack surfaces and attack trees.
- Discuss security controls functions and types
- Discuss the principle aspects of a security strategy.

What is Information Security?

“Is the **protection** of **information** that is stored, transmitted, and processed in a networked system of computers, other digital devices, and network devices and transmission lines, including the Internet. Protection encompasses **confidentiality**, **integrity**, **availability**, **authenticity**, and **accountability**. Methods of protection include **organizational policies** and **procedures**, as well as **technical means** such as encryption and secure communications protocols.” – William Stallings

Key Security Concepts

CIA Triad

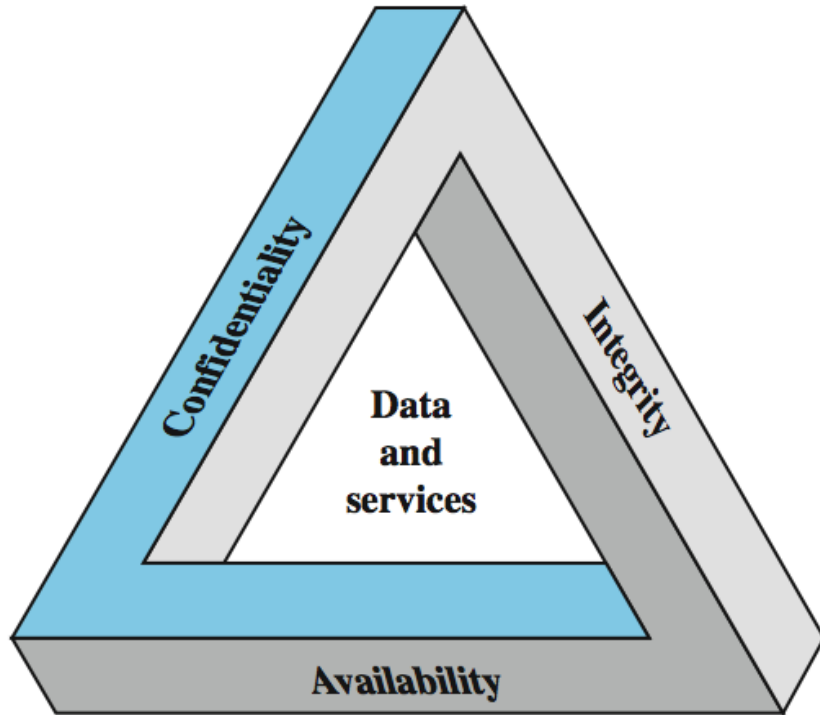


NIST FIPS 199 (year 2004)

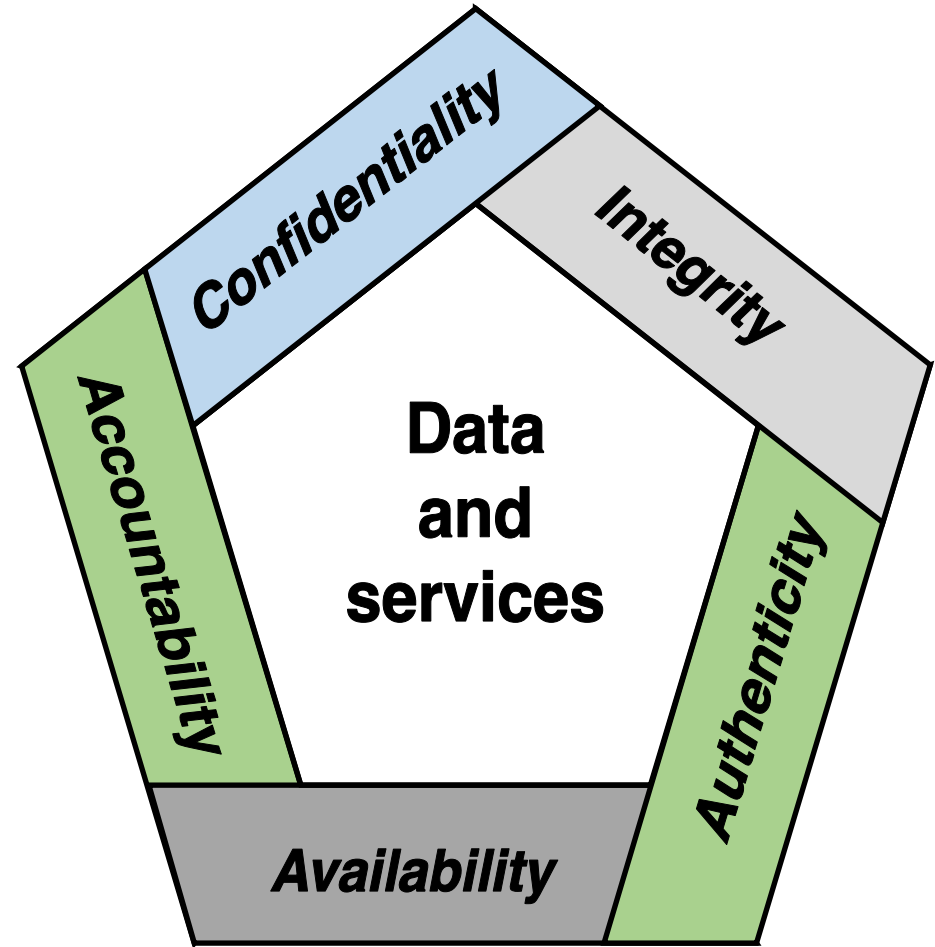
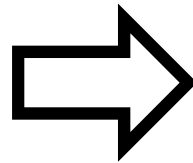
NIST: National Institute of Standards and Technology
FIPS: Federal Information Processing Standards

Key Security Concepts

CIA Triad $\Rightarrow$ *CIAAN*



NIST FIPS 199 (year 2004)



Key Security Concepts

Definitions

Confidentiality

- **Preserving authorized restrictions** on information access and disclosure, including means for protecting personal **privacy** and proprietary information

Integrity

- Guarding against **improper information modification or destruction**, including ensuring information **nonrepudiation** and **authenticity**

Availability

- Ensuring **timely and reliable access** to and use of information to **authorized users**

Authenticity

- The property of being **genuine** and being **able to be verified and trusted**
- Confidence in the **validity of a transmission, a message, or message originator**

Accountability

- called **non-repudiation**
- Ensures that a **party cannot deny having sent or received a message or transaction.**

Balanced Security

- Common Focus in Information Security:
 - Predominantly on confidentiality (keeping secrets secret).
 - Integrity and availability threats often overlooked until compromised.
- Critical Requirements for Different Assets:
 - **Confidentiality:** Company trade secrets.
 - **Integrity:** Financial transaction values.
 - **Availability:** E-commerce web servers.
- Many understand the concepts but not the complexity of implementing necessary controls

Balanced Security (Contd.)

Availability

- Redundant Array of Independent Disks (RAID)
- Clustering
- Load balancing
- Redundant data and power lines
- Software and data backups
- Disk shadowing
- Co-location and offsite facilities
- Rollback functions
- Failover configurations

Integrity

- Hashing (data integrity)
- Configuration management (system integrity)
- Change control (process integrity)
- Access control (physical and technical)
- Software digital signing
- Transmission cyclic redundancy check (CRC) functions

Confidentiality

- Encryption for data at rest (whole disk, database encryption)
- Encryption for data in transit (IPSec, TLS, PPTP, SSH)
- Access control (physical and technical)

Information Security Challenges

1. Information security is not as simple as it might first appear to the novice
2. In developing a particular security mechanism or algorithm, one must always consider potential attacks on those security features
3. Procedures used to provide particular services are often counterintuitive
4. Physical and logical placement needs to be determined
5. Security mechanisms typically involve more than a particular algorithm or protocol and also require that participants be in possession of some secret information which raises questions about the creation, distribution, and protection of that secret information
6. Attackers only need to find a single weakness, while the designer must find and eliminate all weaknesses to achieve perfect security
7. Security is still too often an afterthought to be incorporated into a system after the design is complete, rather than being an integral part of the design process
8. Security requires regular and constant monitoring
9. There is a natural tendency on the part of users and system managers to perceive little benefit from security investment until a security failure occurs
10. Many users and even security administrators view strong security as an impediment to efficient and user-friendly operation of an information system or use of information

Security Breach

Levels of Impact - FIPS 199

A Security Breach is the loss of any attribute of CIA / CIAAN

Impact on organizational operations, organizational assets, or individuals

Low

limited adverse effect;

degradation in mission capability while being able to perform primary functions with degraded effectiveness

Moderate

serious adverse effect;

degradation in mission capability while the effectiveness of the functions is significantly reduced

High

severe or catastrophic adverse effect;

degradation in mission capability while an organization is not able to perform one or more of its primary functions

A Model for Information Security

General Terminology

- **System Resource (Asset)**
 - Any system resource that **users** and **owners** wish to protect.
 - i.e., a major application, general support system, high impact program, physical plant, mission critical system, personnel, equipment, or a logically related group of systems.
 - **Hardware**
 - **Software**
 - **Data**
 - **Communication facilities and networks**

A Model for Information Security

General Terminology (Contd.)

- **Adversary (Threat agent)**

- Individual, group, organization, or government that conducts or has the intent to conduct detrimental activities, i.e. **attack**.

- **Attack**

- Any kind of **malicious activity** that attempts to collect, disrupt, deny, degrade, or destroy information system resources or the information itself.

- **Countermeasure**

- A **device or technique** that has as its objective the impairment of the operational effectiveness of undesirable or **adversarial activity**, or the prevention of espionage, sabotage, theft, or unauthorized access to or use of sensitive information or information systems.

A Model for Information Security

General Terminology (Contd.)

- **Risk**

- A measure of the extent to which an **asset** is threatened by a potential **threat**, and typically a function of:
 1. The likelihood of occurrence.
 2. The adverse impacts that would arise if the circumstance or event occurs

Risk = (Probability that a threat occurs) * (Cost to the asset owner)

- **Security Policy**

- A set of criteria for the provision of security services. It **defines** and **constrains** the **activities** for a system to maintain a condition of security for systems and data.

A Model for Information Security

General Terminology (Contd.)

- **Threat**

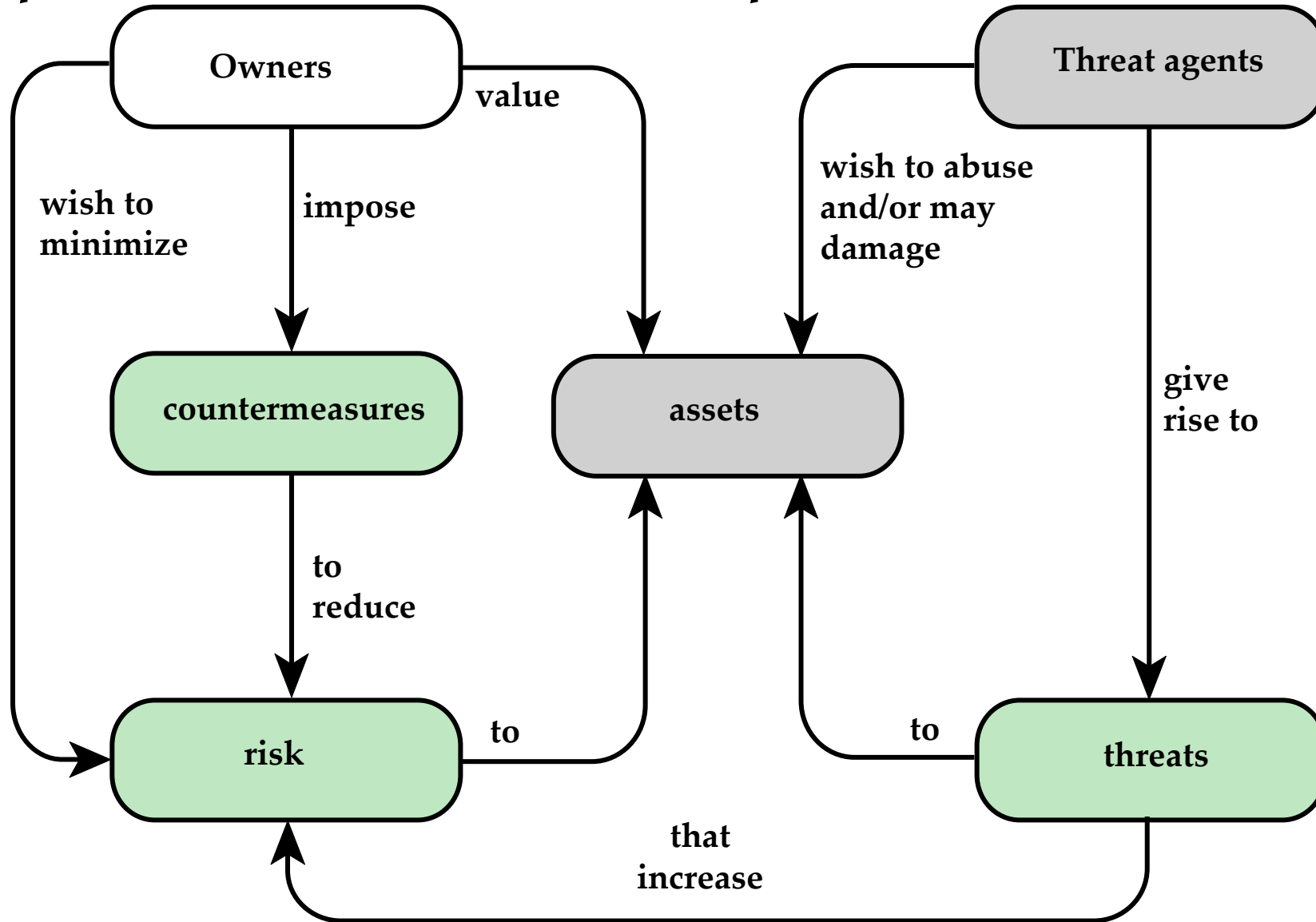
- Any **circumstance or event** with the **potential to adversely impact** organizational operations assets, individuals, other organizations, or a nation **through an information system** via unauthorized access, destruction, disclosure, modification of information, and/or denial of service.

- **Vulnerability**

- **Weakness** in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a **threat** through an **adversary**.

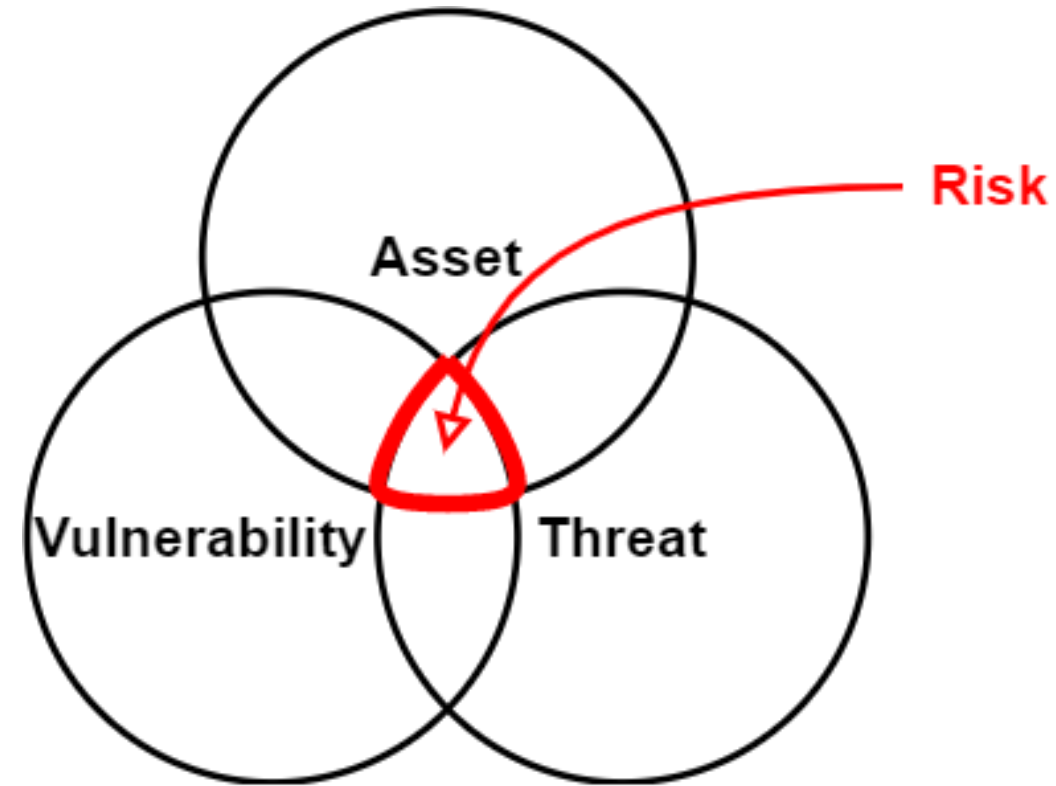
A Model for Information Security

Concepts and Relationships



Vulnerabilities, Threats and Attacks

- **Vulnerabilities** (weakness)
 - Corrupted (loss of integrity).
 - Leaky (loss of confidentiality).
 - Unavailable or very slow (loss of availability).
- **Threats** (exploit vulnerabilities)
 - Capable of exploiting vulnerabilities.
 - Represent potential security harm to an asset.



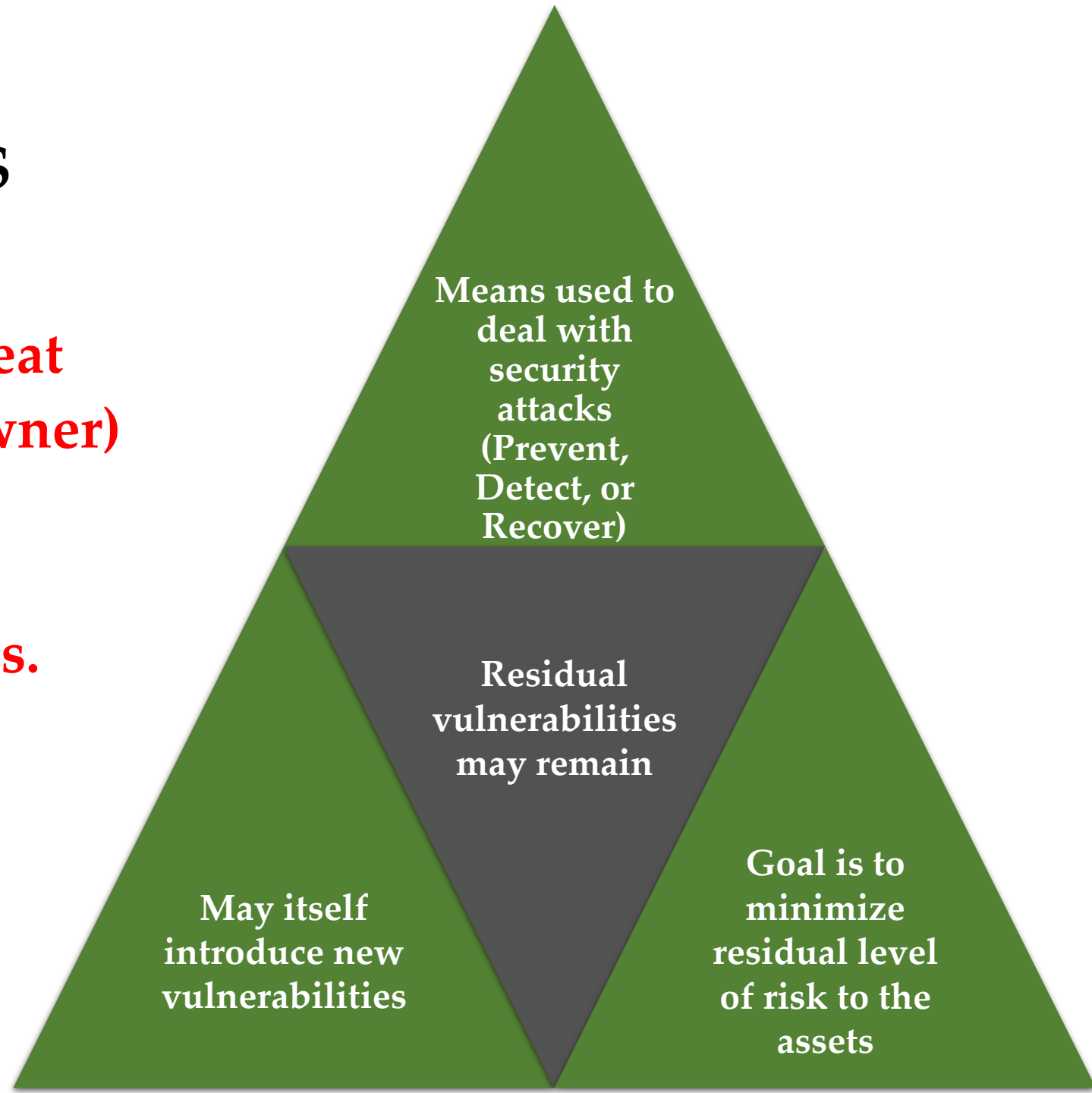
Vulnerabilities, Threats and Attacks (Contd.)

- **Attacks** (threats carried out)
 - **Passive** – attempt to learn or make use of information from the system that does not affect system resources.
 - **Active** – attempt to alter system resources or affect their operation.
 - **Insider** – initiated by an entity inside the security perimeter.
 - **Outsider** – initiated from outside the perimeter.

Countermeasures

Risk = (Probability that a threat occurs) * (Cost to the asset owner)

**Residual Risk =
Total Risk – Countermeasures.**



Threat Consequences, and the Types of Threat Actions that Cause Each Consequence

Threat Consequence	Threat Action (Attack)
Unauthorized Disclosure Violates: Confidentiality A circumstance or event whereby an entity gains access to data for which the entity is not authorized.	Exposure: Sensitive data are directly released to an unauthorized entity. Interception: An unauthorized entity directly accesses sensitive data traveling between authorized sources and destinations. Inference: A threat action whereby an unauthorized entity Indirectly accesses sensitive data (but not necessarily the data contained in the communication) by reasoning from Characteristics or by-products of communications. Intrusion: An unauthorized entity gains access to sensitive data by circumventing a system's security protections.

Threat Consequences, and the Types of Threat Actions that Cause Each Consequence(Contd.)

Threat Consequence	Threat Action (Attack)
Deception Violates: Integrity A circumstance or event that may result in an authorized entity receiving false data and believing it to be true.	Masquerade: An unauthorized entity gains access to a system or performs a malicious act by posing as an authorized entity. Falsification: Altering or replacing of valid data or False data deceive an authorized entity. Repudiation: An entity deceives another by falsely denying responsibility for an act.

Threat Consequences, and the Types of Threat Actions that Cause Each Consequence(Contd.)

Threat Consequence	Threat Action (Attack)
Disruption Violates: Availability A circumstance or event that interrupts or prevents the correct operation of system services and functions.	Incapacitation: Prevents or interrupts system operation by disabling a system component. Corruption: Undesirably alters system operation by adversely modifying system functions or data. Obstruction: A threat action that interrupts delivery of system services by hindering system operation.

Threat Consequences, and the Types of Threat Actions that Cause Each Consequence(Contd.)

Threat Consequence	Threat Action (Attack)
Usurpation Violates: Integrity A circumstance or event that results in control of system services or functions by an unauthorized entity.	Misappropriation: An entity assumes unauthorized logical or physical control of a system resource. Misuse: Causes a system component to perform a function or service that is detrimental to system security.

Assets with Examples of Threats

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service.	An unencrypted CD-ROM or DVD is stolen.	Malicious device modules
Software	Programs are deleted, denying access to users.	An unauthorized copy of software is made.	A working program is modified, either to cause it to fail during execution or to cause it to do some unintended task.
Data	Files are deleted, denying access to users.	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data.	Existing files are modified or new files are fabricated.
Communication Lines and Networks	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable.	Messages are read. The traffic pattern of messages is observed.	Messages are modified, delayed, reordered, or duplicated. False messages are fabricated.

Passive and Active Attacks

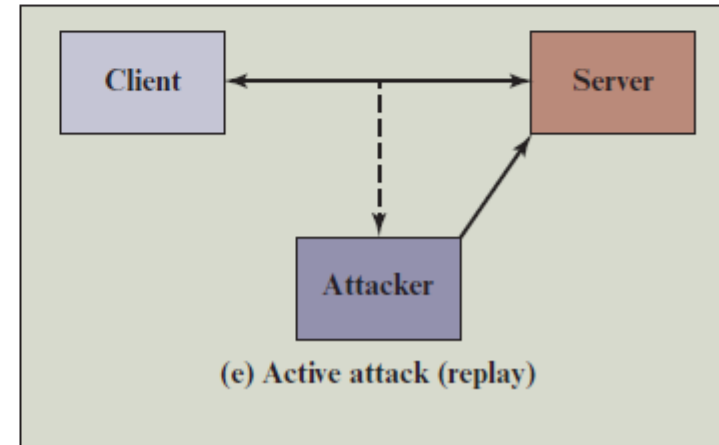
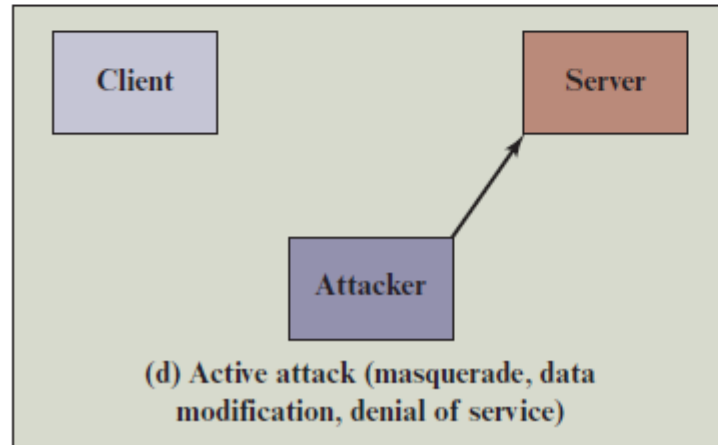
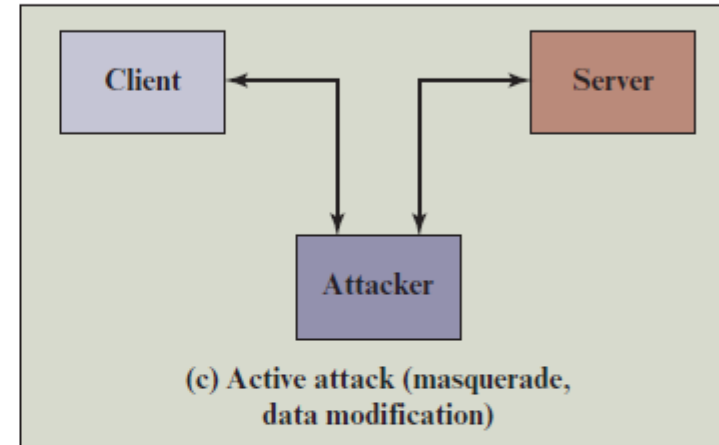
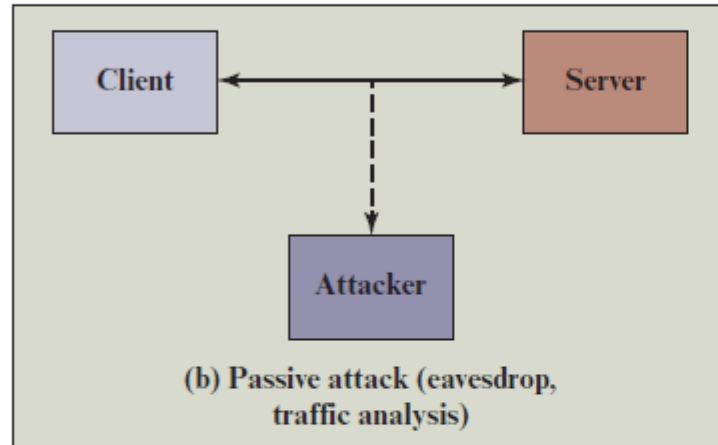
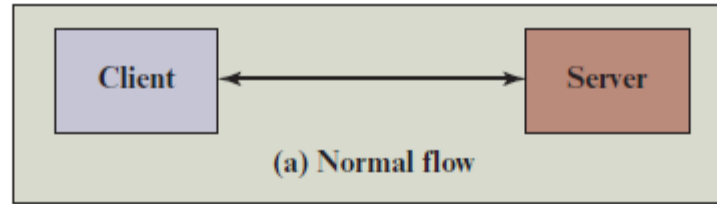
Passive Attack

- Attempts to learn or make use of information from the system but does not affect system resources
(**Reconnaissance**)
- **Eavesdropping** or monitoring transmissions
- Goal of attacker is to obtain information that is being transmitted
- **Categories :**
 - Release of message contents
 - Traffic analysis

Active Attack

- Attempts to alter system resources or affect their operation
- Involve some modification of the data stream or the creation of a false stream
- **Categories:**
 - Replay
 - Masquerade
 - Modification of messages
 - Denial of service

Passive and Active Attacks (Contd.)



Fundamental Security Design Principles

Economy of
mechanism

Fail-safe
defaults

Complete
mediation

Open design

Separation of
privilege

Least privilege

Least
common
mechanism

Psychological
acceptability

Isolation

Encapsulation

Modularity

Layering

Least
astonishment

Attack Surfaces

Consist of the reachable and exploitable vulnerabilities in a system

Examples:

Open ports on outward facing Web and other servers, and code listening on those ports

Services available on the inside of a firewall

Code that processes incoming data, email, XML, office documents, and industry-specific custom data exchange formats

Interfaces, SQL, and Web forms

An employee with access to sensitive information vulnerable to a social engineering attack

Attack Surface Categories

Network Attack Surface

- Vulnerabilities over an enterprise network, wide-area network, or the Internet.
- Such as network protocol vulnerabilities, i.e. denial-of-service attack, disruption of communications links.

Software Attack Surface

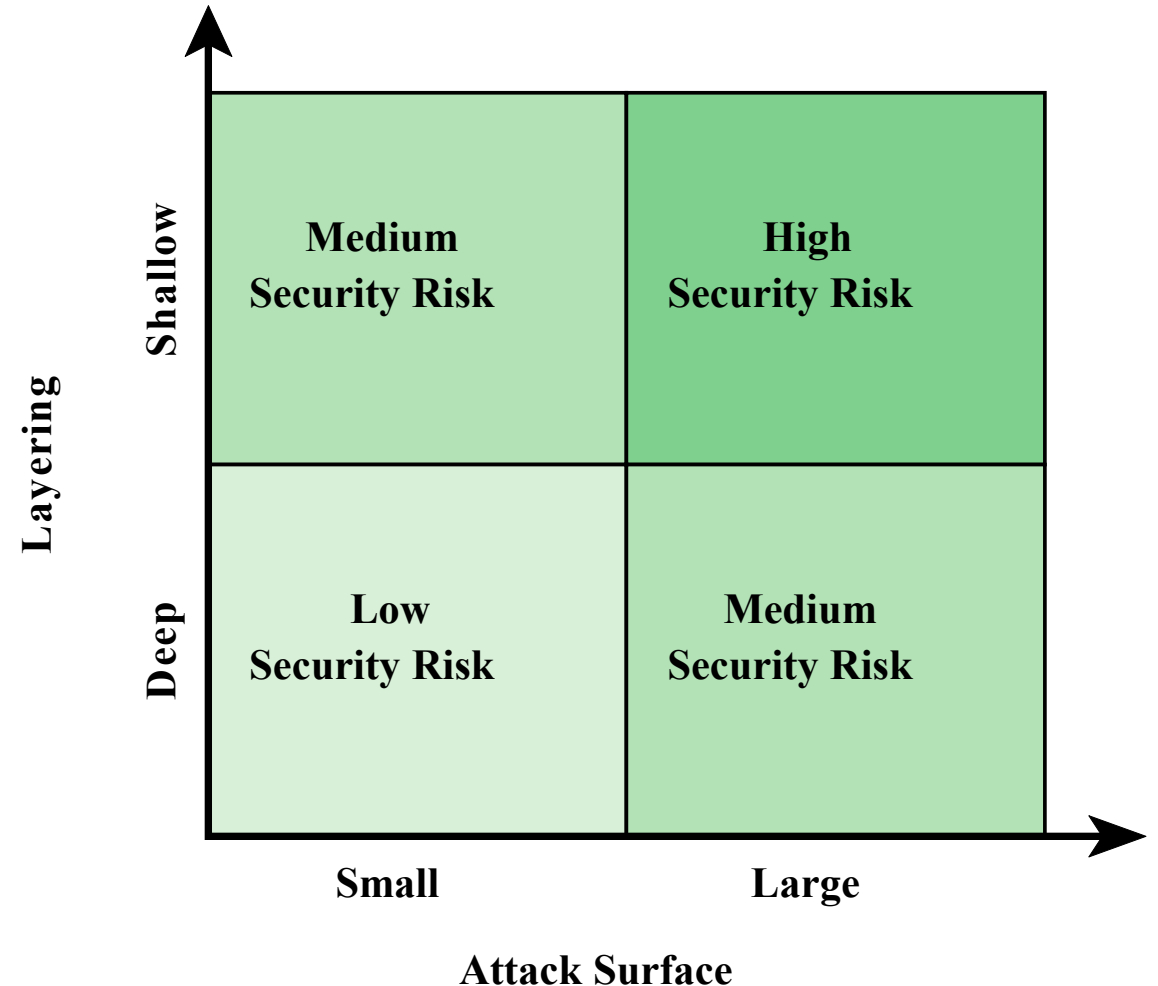
- Vulnerabilities in application, utility, or operating system code
- Particular focus is Web server software.

Human Attack Surface

- Vulnerabilities created by personnel or outsiders, such as social engineering, human error, and trusted insiders.

Layering (Defense in Depth) and Attack Surface

- The use of layering, or defense in depth, and attack surface reduction complement each other in mitigating security risk.



Security Controls

Functions

- Security Controls are mechanisms put into place to reduce the risk an organization faces, and they come in **three main functions**:
 - **Administrative**: commonly referred to as “**soft controls**” because they are more management oriented. i.e. security documentation, risk management, personnel security, and training.
 - **Technical**: software or hardware components, as in firewalls, IDS, encryption, and identification and authentication mechanisms. Sometimes called **logical controls**
 - **Physical**: items put into place to protect facilities, personnel, and resources. i.e. security guards, locks, fencing, and lighting

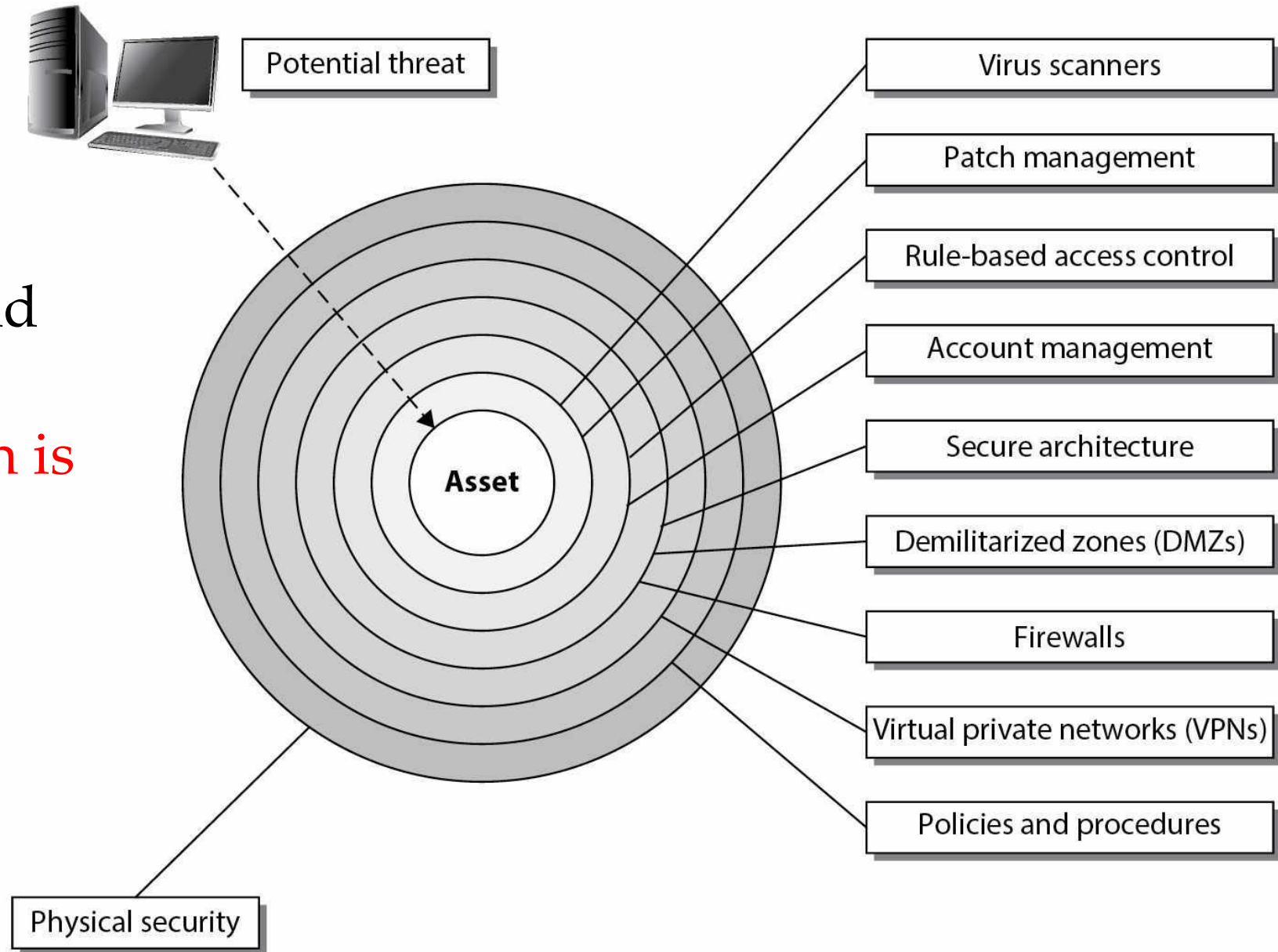
Security Control *Types*

- **Preventive:** Intended to avoid an incident from occurring
- **Detective:** Helps identify an incident's activities and potentially an intruder
- **Corrective:** Fixes components or systems after an incident has occurred
- **Deterrent:** Intended to discourage a potential attacker
- **Recovery:** Intended to bring the environment back to regular operations
- **Compensating Controls:** that provide an alternative measure of control

Defense in Depth

- **Relate to:** Security Controls functions and types.

Can you identify which is which?



Security Control

Functions vs. Types

Functionality:	Preventive	Detective	Corrective	Deterrent	Recovery
Type:					
Physical					
Fences				X	
Locks	X				
Badge system	X				
Security guard	X				
Biometric system	X				
Mantrap doors	X				
Lighting				X	
Motion detectors		X			
Closed-circuit TVs		X			
Offsite facility					X

Functionality:	Preventive	Detective	Corrective	Deterrent	Recovery
Type:					
Administrative					
Security policy	X				
Monitoring and supervising		X			
Separation of duties	X				
Job rotation		X			
Information classification	X				
Personnel procedures	X				
Investigations		X			
Testing	X				
Security awareness training	X				

Functionality:	Preventive	Detective	Corrective	Deterrent	Recovery
Type:					
Technical					
ACLs	X				
Encryption	X				
Audit logs		X			
IDS		X			
Antivirus software	X				
Server images			X		
Smart cards	X				
Dial-up call-back systems	X				
Data backup					X

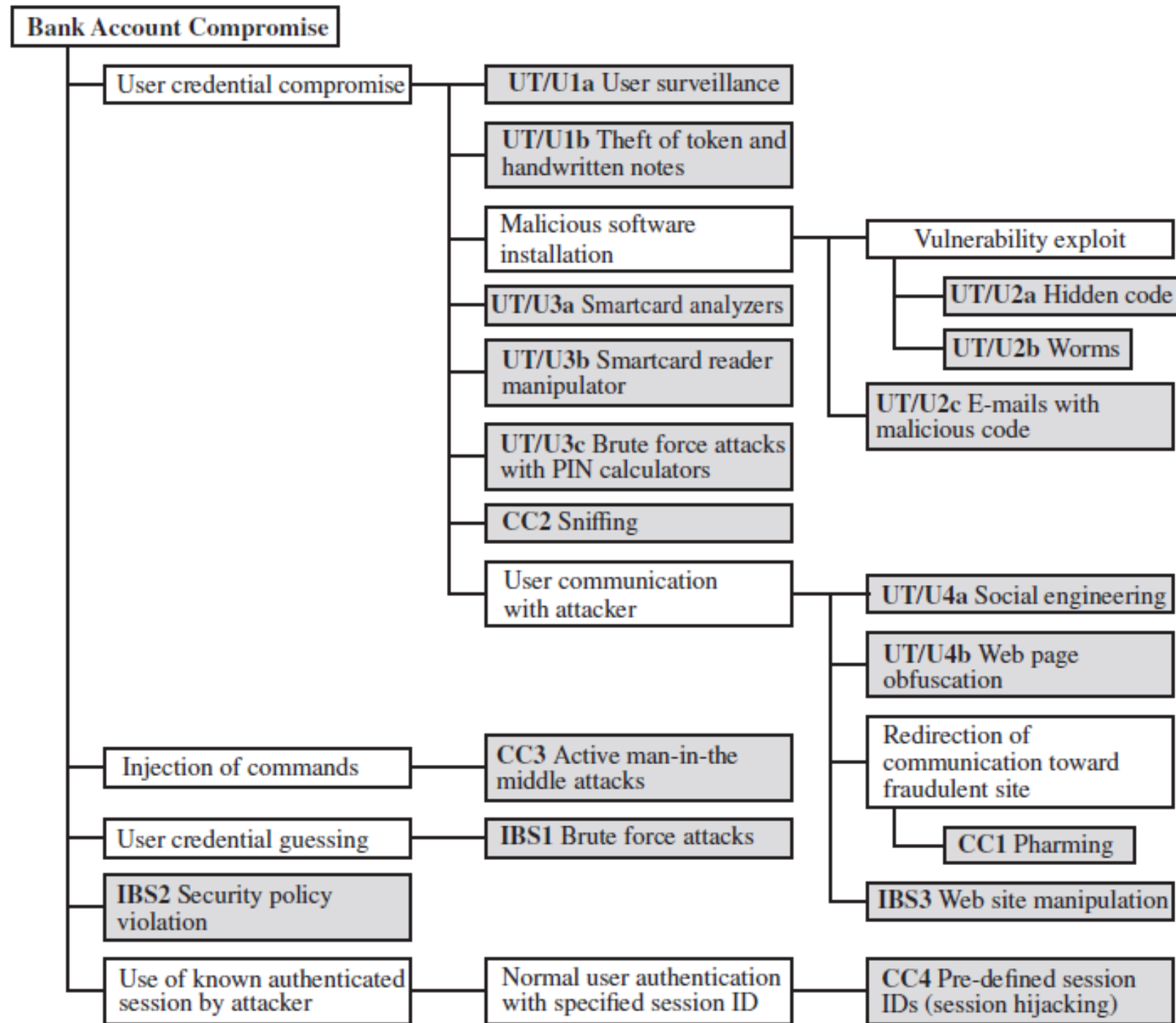
Attack Tree

- An attack tree is a data structure that represents a set of potential techniques for exploiting security vulnerabilities.
- The security incident (goal of the attack) is represented as the root node of the tree.
- The ways by which an attacker could reach that goal are iteratively and incrementally represented as branches and sub nodes of the tree.
- Each sub node defines a subgoal, and each subgoal may have its own set of further subgoals, and so on. .

Attack Tree

- The leaf nodes, represent different ways to initiate an attack.
- Each node other than a leaf is either an AND-node or an OR-node.
- Branches can be labeled with values representing difficulty, cost, or other attack attributes, so that alternative attacks can be compared.
- Guides both the design of systems and applications, and the choice and strength of countermeasures.

An Attack Tree for Bank Account Compromise



User terminal and user (UT/U)
Communications channel (CC)
Internet banking server (IBS)

Security Strategy

Security Policy

- Formal statement of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources

Security Implementation

- Involves four complementary courses of action:
 - Prevention
 - Detection
 - Response
 - Recovery

Assurance

- For both system design and system implementation, assurance is an attribute of an information system that provides grounds for having confidence that the system operates such that the system's security policy is enforced

Evaluation

- Process of examining a system with respect to certain criteria
- Involves testing and may also involve formal analytic or mathematical techniques

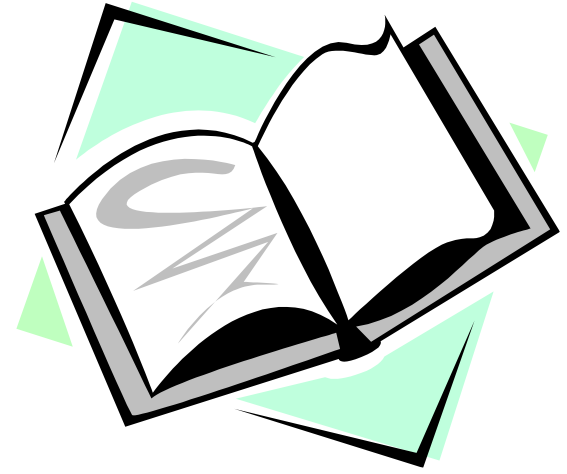
Standards

- Standards cover management practices and the overall architecture of security mechanisms and services
 - National Institute of Standards and Technology (**NIST**)
 - A **U.S. federal agency**
 - Internet Society (**ISOC**)
 - A **professional membership** society
 - International Telecommunication Union (**ITU-T**)
 - A **United Nations** agency
 - International Organization for Standardization (**ISO**)
 - A **nongovernmental organization** for International Standards

Summary

- Information security concepts
 - Definition
 - Challenges
 - Model
- Threats, attacks, and assets
 - Threats and attacks
 - Threats and assets
- Security functional requirements
- Fundamental security design principles
- Attack surfaces and attack trees
 - Attack surfaces
 - Attack trees
- Security Controls
- Information security strategy
- Standards

Readings, Assignments and Labs



- Computer Security - Principles and Practice, 4th Global Edition - William Stallings - Ch 1
- Additional Resource (optional):
 - FIPS 199 <https://csrc.nist.gov/pubs/fips/199/final>
 - FIPS 200 <https://csrc.nist.gov/pubs/fips/200/final>
- **Coursera**
 - **EC-Council** - Ethical Hacking Essentials (EHE) – Module 3
- Assignment #01
- Lab #01 - Lab Setup (1/2) – Virtualization
- Tutorial #01

Questions?

Thank You